PERPETUAL MOTION SQUAD

POCKETEXPENSE+

Validation Report

Production-Grade Offline-First Financial Tracking System

Purvansh Sahu   Yash Arya   Aman Anand

TEAM	**Perpetual Motion Squad**
DEGREE	**BSc (Hons) in Computer Science**
INSTITUTION	**BITS Pilani**
PROJECT GUIDE	**Mr. Murali Raghu**
DATE	**August 2026**
DOCUMENT	**Validation Report**

1. Executive Summary

PocketExpense+ was validated against a comprehensive program of **198 automated tests** (96 backend + 102 frontend), static analysis, load testing, and architectural review.

Result: all 198 tests pass · 12/12 features functional · 0 critical · 0 major defects · SMS 99% accuracy with 0% false positives.

Verdict: **APPROVED for production deployment** (subject to §8 deployment considerations).

2. Scope and Methodology

Scope: functional correctness of all twelve features; non-functional properties (performance, security, privacy, reliability, usability); production readiness.

Methodology: four techniques: (1) automated testing — 198 Jest tests (backend against in-memory MongoDB); (2) static verification — `tsc --noEmit` and `expo lint` at zero errors; (3) load testing — Artillery enforcing p95 < 500 ms and p99 < 1000 ms at 100 concurrent users / 500 req/min; (4) architectural and security review.

3. Acceptance Criteria

#	Criterion	Result
AC-1	All 198 automated tests pass	**PASS**
AC-2	SMS detection accuracy ≥ 95%	**PASS** (99%)
AC-3	SMS false-positive rate ≤ 3%	**PASS** (0%)
AC-4	Offline-first operation without connectivity	**PASS**
AC-5	Budget alerts fire at configured thresholds	**PASS**
AC-6	Recurring transactions idempotent	**PASS**
AC-7	All private routes require a valid JWT	**PASS**
AC-8	No SMS content stored or transmitted	**PASS**
AC-9	Performance targets (p95 < 500 ms, p99 < 1000 ms)	**PASS**
AC-10	All security checklist items implemented	**PASS**

4. Functional Validation

Each feature was exercised against its acceptance cases (see 02-Test-Cases.pdf for the full test case catalogue). All recorded results pass.

Feature	Validated Behaviours (representative cases)	Result
Authentication	Registration, login, JWT-protected profile, duplicate/invalid rejection, expired/malformed tokens, cross-user denial (TC-B49–55, B83–85)	PASS
Expenses + Sync	CRUD, validation, pagination, sync reconciliation, tombstones, bulk delete, offline queue (TC-B01–15, B90–91, F87–90)	PASS
Budgets + Alerts	CRUD, unique index, virtuals, recalculation, threshold crossings, once-per-month dedup (TC-B16–27, F75–86)	PASS
Recurring	Daily/weekly/monthly scheduling, cloning, idempotency, month-end rollover (TC-B28–37, B88–89)	PASS
Filtering + Pagination	Query params, limit cap, large-volume handling (TC-B08–09, B69–71)	PASS
Insights	Growth, top categories, weekday/weekend, anomalies, empty data (TC-B38–48)	PASS
Receipt OCR	Weighted total extraction, subtotal/tax rejection, merchant/date, confidence, guardrails (TC-F43–58)	PASS
SMS Detection	200-sample accuracy, OTP/promo rejection, routing, gating, dedup, category mapping (TC-F01–42)	PASS
Export	CSV escaping/signing, PDF HTML escaping, period windowing (TC-F59–74)	PASS
Notifications	Android channel, Expo Go guard, prefs persistence, feed cap	PASS
Theme	Light/dark/system, persistence, no scheme flash, dark-aware shadows	PASS
Production Hardening	Joi validation, error handling, rate limits, graceful shutdown (TC-B57, B80–82, B86–87)	PASS

5. Non-Functional Validation

5.1 Performance

Metric	Target	Result
p95 response time	< 500 ms	PASS
p99 response time	< 1000 ms	PASS
Concurrent users	100	PASS
Request rate	500 requests/min	PASS

Artillery load test fails the run if either latency target is breached. Insights aggregation ~200 ms typical; indexes align to query shapes.

5.2 Security

Control	Validated
Helmet headers (CSP, HSTS, X-Frame-Options, X-Content-Type-Options)	✓
NoSQL injection prevention (express-mongo-sanitize)	✓
HTTP parameter pollution prevention (hpp)	✓
Rate limiting (100 req/15min API, 20 req/15min auth)	✓
JWT verification on all private routes	✓
bcrypt hashing (10 rounds); password `select:false`	✓
Joi validation on all endpoints; unknown fields stripped	✓
Stack traces hidden in production; CORS allowlist; 10MB body limit	✓
Graceful shutdown (SIGTERM/SIGINT)	✓
CSV formula-injection escaping; HTML escaping in PDF exports	✓

5.3 Privacy

Principle	Validated
SMS parsed locally, never transmitted	✓
No raw SMS storage or logging	✓
Feature off by default; user-controlled and revocable	✓
Minimal permissions (READ_SMS, RECEIVE_SMS only)	✓
Backend exposes no endpoint receiving SMS content	✓
Deduplication hashes non-reversible	✓

5.4 Reliability

Mechanism	Validated
Offline-first: all core operations work without connectivity	✓
Exponential backoff capped at 5 minutes	✓
Tombstones prevent deleted-record resurrection	✓
Paged pull capped at 20 pages / 100 records	✓
Recurring idempotency; sync reconciliation via localId → serverId	✓

Force sync; delete retry cap (MAX_DELETE_ATTEMPTS = 5)	✓

5.5 Usability

Aspect	Validated
Tab navigation (Home, Transactions, Analytics, Account)	✓
Haptic feedback; filters with active badge + reset	✓
Bulk selection mode with count indicator	✓
Sync indicator (offline / syncing / pending)	✓
Undo toast for auto-added SMS transactions (6s)	✓
Date-picker month navigation	✓

6. Validation Matrix

Feature Category	Test Count	Passed	Failed	Status
Expense Service	15	15	0	PASS
Budget Service	12	12	0	PASS
Recurring Service	10	10	0	PASS
Insight Service	11	11	0	PASS
API Integration	17	17	0	PASS
Edge Cases	31	31	0	PASS
SMS Parser	42	42	0	PASS
Receipt Parser	16	16	0	PASS
Export Format	16	16	0	PASS
Budget Thresholds	12	12	0	PASS
Bulk Delete	4	4	0	PASS
Stats	12	12	0	PASS
Total	**198**	**198**	**0**	APPROVED

6.1 Defect Summary

Severity	Open Defects	Notes
Critical	0	—
Major	0	—
Minor	0	All observed issues resolved during development

6.2 Quality Metrics

Metric	Target	Actual	Result
SMS detection accuracy	≥ 95%	99%	PASS
SMS false-positive rate	≤ 3%	0%	PASS
SMS average confidence	≥ 0.6	0.92	PASS
OTP / promo rejection	100%	100%	PASS
Backend statement coverage	—	~82%	PASS
Backend route coverage	100%	100%	PASS

7. Risk Assessment

ID	Risk	Likelihood	Impact	Rating	Mitigation
R1	Bank SMS format drift	Med	Med	MEDIUM	Drift → ignored rather than misparsed, preserving 0% false positives
R2	Expo SDK breaking changes	Low	Med	LOW	Provider isolation layers contain the blast radius
R3	Sync conflicts on shared records	Low	Low	LOW	Tombstones + idempotent reconciliation
R4	Rate limiting blocking legitimate bursts	Low	Low	LOW	Separate limiters; configurable window/max
R5	Notification permission denied	Med	Low	LOW	In-app feed preserves alert history
R6	Aggregation latency growth	Low	Low	LOW	Indexes aligned; Redis cache upgrade path
R7	OCR unavailable in Expo Go	High	Low	LOW	Degrades to photo attach; documented

Overall risk rating: 🟢 **LOW**. The sole MEDIUM risk (R1) has a built-in degradation path that preserves the zero-false-positive property.

7.1 Deployment Considerations

Consideration	Recommendation
Multiple server instances	Hourly cron runs in-process without a distributed lock — deploy a single instance or add an atomic claim before scaling
JWT_SECRET	Must be set, at least 32 characters
CORS_ORIGIN	Defaults to `*`; restrict to known origins in production
Client API URL	Supply via environment configuration, not compiled in

8. Conclusion

The validation exercise executed 198 automated test cases across six backend and six frontend suites, supplemented by static verification, load testing, and architectural review. All 198 tests passed; all ten acceptance criteria were met, with SMS accuracy and false-positive rate exceeded by a substantial margin. All security controls were verified present and effective; all privacy principles were confirmed, including the structural guarantee that the backend exposes no endpoint capable of receiving message content.

Zero critical and zero major defects remain open. Non-functional properties — performance targets, security controls, privacy guarantees, offline reliability, and usability affordances — were all validated as implemented.

> **Overall verdict: APPROVED for production deployment.** Before production, apply §7.1: single-instance cron deployment, explicit JWT_SECRET and CORS_ORIGIN, and environment-driven client configuration.

Supporting evidence: 02-Test-Cases.pdf (test case documentation) and 01-Project-Report.pdf (full system documentation).